AI GOVERNANCE, RISK & COMPLIANCE

AI Risk Assessment & Governance Gap Analysis

AI-Powered Resume Screening Tool | HR Technology Organization

Prepared by: Tamia Williams

Assessment Date: 2025 | Classification: Portfolio Sample

Primary Framework: NIST AI RMF (AI 100-1) | Supporting: NIST SP 800-53, NYC Local Law 144, EEOC Guidelines

AI Risks Identified	Critical Risks	Governance Gaps	RMF Functions Assessed
8	3	8	4

Section 1 — *Executive Summary*

Engagement Context This report presents an AI governance risk assessment for a simulated HR technology company deploying an AI-powered resume screening tool. The tool automatically filters job applications before human review, using machine learning to rank candidates based on resume content. As AI-driven hiring tools become increasingly common, they introduce a distinct category of risk — including algorithmic bias, lack of transparency, regulatory exposure, and accountability gaps — that traditional GRC frameworks do not fully address.

Assessment Purpose This assessment evaluates the organization's AI deployment posture against the NIST Artificial Intelligence Risk Management Framework (AI RMF, NIST AI 100-1), which defines four core functions: Govern, Map, Measure, and Manage. The assessment identifies risks specific to AI systems, analyzes gaps in the organization's current governance posture, and delivers a prioritized remediation roadmap.

Why AI Hiring Tools Carry Elevated Risk Resume screening AI is one of the most legally and ethically scrutinized AI use cases. Historical deployments have demonstrated measurable bias against women, older workers, and racial minorities. Regulatory pressure is increasing: New York City's Local Law 144 requires annual bias audits for automated employment decision tools, and similar legislation is expanding nationally. The consequences of ungoverned AI hiring tools include EEOC enforcement actions, reputational damage, and civil litigation.

Critical Issues Identified	Immediate Priorities
❗ No AI governance policy or accountability structure in place	✅ Develop and publish AI Governance Policy immediately
❗ No bias or fairness testing conducted on screening model	✅ Commission disparate impact bias audit before next hiring cycle
❗ Non-compliant with NYC Local Law 144 bias audit requirements	✅ Conduct legal review against NYC LL144 and EEOC guidelines
❗ Candidate PII processed without consent or retention controls	✅ Implement consent management and data minimization controls
❗ No explainability mechanism for AI rejection decisions	✅ Deploy explainable AI (XAI) mechanism for candidate decisions
❗ Third-party AI vendor lacks contractual governance controls	✅ Add AI governance clauses to vendor contracts
❗ No post-deployment monitoring or model drift detection	✅ Establish continuous monitoring and retraining schedule

Overall AI Risk Posture The organization's current AI governance posture is critically immature. Three of eight identified risks are rated Critical, and all four NIST AI RMF functions show significant gaps. The absence of any formal AI governance structure means risks are accumulating without oversight. Immediate action is required on bias auditing, regulatory compliance, and governance policy development before the next hiring cycle.

Section 2 — *NIST AI RMF — Framework Overview*

The NIST Artificial Intelligence Risk Management Framework (NIST AI 100-1, 2023) provides a voluntary, non-prescriptive framework for managing risks throughout the AI system lifecycle. It defines four core functions:

Function	Focus Area	Purpose	Applied to This Assessment
GOVERN	**Accountability**	Establishes organizational policies, roles, and cultures that embed AI risk management into operations	Evaluate governance policy, accountability structures, and executive oversight of AI hiring tool
MAP	**Context**	Identifies and categorizes AI risks in the context of the specific system, use case, and affected populations	Map risks specific to resume screening including bias, legal exposure, and third-party dependencies
MEASURE	**Evaluation**	Analyzes and assesses AI risks using quantitative and qualitative methods including bias testing and performance evaluation	Measure fairness metrics, privacy risk, model performance, and security vulnerabilities
MANAGE	**Response**	Prioritizes and responds to identified AI risks through treatment plans, monitoring, and incident response	Define risk responses, establish monitoring program, and build AI incident response capability

Section 3 — *AI Risk Register*

Eight risks were identified across four AI risk categories. Each risk is mapped to the applicable NIST AI RMF function, scored by likelihood and impact, and assigned a recommended control.

ID	Category	RMF Fn.	Risk	Likelihood	Impact	Score	Owner	Status
AIR-001	**Bias & Fairness**	MAP	Algorithmic bias in resume screening produces disparate outcomes for protected classes (race, gender, age, disability)	4/5	5/5	20	Chief People Officer	Open
AIR-002	**Transparency**	GOVERN	Candidates receive no explanation for AI-driven rejection decisions, violating explainability expectations and emerging regulations	4/5	4/5	16	Chief Compliance Officer	Open
AIR-003	**Data Privacy**	MEASURE	Resume data including PII processed by AI model without documented consent, retention policy, or data minimization controls	3/5	5/5	15	Data Protection Officer	Open
AIR-004	**Model Security**	MANAGE	AI model vulnerable to adversarial inputs — candidates can manipulate resume keywords to game screening outcomes	4/5	3/5	12	AI Engineering Lead	Open
AIR-005	**Accountability**	GOVERN	No defined human oversight or appeal process for AI screening decisions — no single owner accountable for model outcomes	3/5	4/5	12	Chief Compliance Officer	Open
AIR-006	**Model Drift**	MEASURE	AI model performance degrades over time as labor market conditions change — no monitoring or retraining schedule in place	3/5	4/5	12	AI Engineering Lead	Open
AIR-007	**Third-Party Risk**	MAP	Reliance on third-party AI vendor with no AI-specific contractual controls, audit rights, or model transparency requirements	3/5	4/5	12	Chief Procurement Officer	Open
AIR-008	**Legal & Regulatory**	GOVERN	Non-compliance with emerging AI hiring regulations including NYC Local Law 144 (automated employment decision tools)	4/5	5/5	20	Chief Compliance Officer	Open

Section 3.1 — *Risk Detail Cards*

AIR-001 | Bias & Fairness | RMF Function: MAP	
Risk Description	Algorithmic bias in resume screening produces disparate outcomes for protected classes (race, gender, age, disability)
Likelihood	**4 / 5**
Impact	**5 / 5**
Risk Score	**20 — CRITICAL**
Recommended Controls	Fairness audits using disparate impact testing; diverse training data requirements; human review of all AI rejections
Accountable Owner	Chief People Officer

AIR-002 | Transparency | RMF Function: GOVERN	
Risk Description	Candidates receive no explanation for AI-driven rejection decisions, violating explainability expectations and emerging regulations
Likelihood	**4 / 5**
Impact	**4 / 5**
Risk Score	**16 — HIGH**
Recommended Controls	Implement explainable AI (XAI) mechanisms; provide candidates with decision rationale; document model decision logic
Accountable Owner	Chief Compliance Officer

AIR-003 | Data Privacy | RMF Function: MEASURE	
Risk Description	Resume data including PII processed by AI model without documented consent, retention policy, or data minimization controls
Likelihood	**3 / 5**
Impact	**5 / 5**
Risk Score	**15 — HIGH**
Recommended Controls	Implement consent management; define data retention and deletion schedules; apply data minimization to training datasets
Accountable Owner	Data Protection Officer

AIR-004 | Model Security | RMF Function: MANAGE	
Risk Description	AI model vulnerable to adversarial inputs — candidates can manipulate resume keywords to game screening outcomes

Likelihood	**4 / 5**
Impact	**3 / 5**
Risk Score	**12 — HIGH**
Recommended Controls	Adversarial input testing; input validation; model robustness testing; anomaly detection on screening patterns
Accountable Owner	AI Engineering Lead

AIR-005 | Accountability | RMF Function: GOVERN	
Risk Description	No defined human oversight or appeal process for AI screening decisions — no single owner accountable for model outcomes
Likelihood	**3 / 5**
Impact	**4 / 5**
Risk Score	**12 — HIGH**
Recommended Controls	Designate AI Accountability Officer; establish appeals process; define escalation path for disputed decisions
Accountable Owner	Chief Compliance Officer

AIR-006 | Model Drift | RMF Function: MEASURE	
Risk Description	AI model performance degrades over time as labor market conditions change — no monitoring or retraining schedule in place
Likelihood	**3 / 5**
Impact	**4 / 5**
Risk Score	**12 — HIGH**
Recommended Controls	Implement continuous performance monitoring; establish retraining triggers; track accuracy and fairness metrics over time
Accountable Owner	AI Engineering Lead

AIR-007 | Third-Party Risk | RMF Function: MAP	
Risk Description	Reliance on third-party AI vendor with no AI-specific contractual controls, audit rights, or model transparency requirements
Likelihood	**3 / 5**
Impact	**4 / 5**
Risk Score	**12 — HIGH**
Recommended Controls	Add AI governance clauses to vendor contracts; require SOC 2 Type II and model cards; establish right to audit
Accountable Owner	Chief Procurement Officer

AIR-008 | Legal & Regulatory | RMF Function: GOVERN	
Risk Description	Non-compliance with emerging AI hiring regulations including NYC Local Law 144 (automated employment decision tools)
Likelihood	**4 / 5**
Impact	**5 / 5**
Risk Score	**20 — CRITICAL**
Recommended Controls	Conduct annual bias audits per NYC LL144; publish audit results; notify candidates of AI use in hiring
Accountable Owner	Chief Compliance Officer

Section 4 — *NIST AI RMF Gap Analysis*

The following gap analysis evaluates the organization's current AI governance posture against eight NIST AI RMF subcategory requirements across all four functions. Each gap is rated by severity and accompanied by a specific recommendation.

Function	Subcategory	Requirement	Current State	Gap	Recommendation
GOVERN	GOVERN 1.1	Policies, processes, and accountability structures are established for AI risk management	No formal AI governance policy exists. AI deployment decisions made ad hoc without documented accountability.	CRITICAL	Develop and publish an AI Governance Policy; designate an AI Accountability Officer; establish an AI Risk Committee
GOVERN	GOVERN 1.2	Roles and responsibilities for AI risk management are defined and assigned	No defined roles for AI oversight. Engineering team owns model but has no compliance or ethics mandate.	HIGH	Define AI-specific roles: AI Product Owner, AI Ethics Reviewer, Data Protection Officer with AI mandate
MAP	MAP 1.1	Context is established for the AI system including intended use, affected populations, and potential impacts	Intended use documented in product spec but affected populations (job candidates) and societal impacts not formally assessed.	HIGH	Conduct AI Impact Assessment documenting affected populations, potential harms, and societal implications
MAP	MAP 2.2	Scientific findings, legal requirements, and stakeholder feedback are considered in AI deployment	No legal review of AI hiring regulations conducted. NYC Local Law 144 requirements not assessed.	CRITICAL	Conduct legal review against NYC LL144, EEOC guidelines, and applicable state AI hiring laws
MEASURE	MEASURE 2.5	AI system fairness and bias are evaluated using appropriate metrics	No bias testing or fairness evaluation has been conducted on the screening model.	CRITICAL	Implement disparate impact testing across protected classes; conduct pre-deployment and annual fairness audits
MEASURE	MEASURE 2.9	Privacy risks of AI systems are assessed and managed	Resume PII processed without documented privacy impact assessment or data minimization controls.	HIGH	Conduct AI Privacy Impact Assessment; implement consent management and data retention controls
MANAGE	MANAGE 1.3	Responses to identified AI risks are planned and implemented	No formal risk response process exists. Identified issues are addressed informally without documentation.	HIGH	Establish AI risk response playbook; integrate AI risks into enterprise risk register and POA&M
MANAGE	MANAGE 4.1	Post-deployment AI system performance is monitored and incidents are reported	No monitoring or performance tracking in place post-deployment. No incident reporting process for AI failures.	HIGH	Implement continuous monitoring dashboard; establish AI incident reporting and escalation process

Section 5 — *Remediation Roadmap*

Remediation actions are prioritized across three phases based on risk severity, regulatory urgency, and implementation complexity.

Phase	Priority	Action	Owner	Timeline
1 — Immediate	CRITICAL	Halt AI screening for any role until bias audit is completed and NYC LL144 compliance is confirmed	Chief Compliance Officer	**Within 30 days**
1 — Immediate	CRITICAL	Commission independent disparate impact bias audit across all protected classes	Chief People Officer	**Within 30 days**
1 — Immediate	CRITICAL	Develop and publish AI Governance Policy; designate AI Accountability Officer	Chief Compliance Officer	**Within 30 days**
2 — Short-term	HIGH	Conduct legal review against NYC Local Law 144, EEOC guidelines, and applicable state AI hiring laws	Chief Compliance Officer	**30-60 days**
2 — Short-term	HIGH	Implement consent management; notify candidates AI is used in screening process	Data Protection Officer	**30-60 days**
2 — Short-term	HIGH	Add AI governance clauses to vendor contract; require model card and audit rights	Chief Procurement Officer	**30-60 days**
2 — Short-term	HIGH	Deploy explainable AI (XAI) mechanism; provide candidates with decision rationale	AI Engineering Lead	**45-90 days**
3 — Medium-term	MODERATE	Implement continuous monitoring dashboard tracking fairness and performance metrics	AI Engineering Lead	**60-90 days**
3 — Medium-term	MODERATE	Establish AI incident response process and integrate AI risks into enterprise risk register	Chief Compliance Officer	**60-90 days**
3 — Medium-term	MODERATE	Define model retraining schedule and performance degradation thresholds	AI Engineering Lead	**90 days**

Section 6 — *AI Regulatory Landscape — Hiring Tools*

AI-powered hiring tools are subject to a rapidly evolving regulatory environment. The following regulations apply directly to the organization's use case and must be addressed in the governance program.

Regulation	Jurisdiction	Key Requirements	Compliance Gap
NYC Local Law 144 (2023)	New York City	Annual independent bias audit required for all automated employment decision tools (AEDTs); results must be published; candidates must be notified AI is used	No bias audit conducted; no candidate notification in place; non-compliant
EEOC Guidance on AI Hiring	Federal (US)	AI hiring tools must not produce disparate impact on protected classes under Title VII; employer remains liable for AI-driven discrimination	No disparate impact testing; no documentation of protected class outcomes
NIST AI RMF (AI 100-1)	Federal Best Practice	Voluntary framework for managing AI risks across Govern, Map, Measure, and Manage functions	Significant gaps across all four functions as documented in Section 4
Illinois AI Video Interview Act	Illinois	Requires employer consent and disclosure before using AI to analyze video interviews; restricts data sharing	Scope depends on hiring locations; legal review recommended
Colorado AI Act (2024)	Colorado	High-risk AI systems in employment must conduct impact assessments and disclose AI use to affected individuals	No impact assessment conducted; no disclosure mechanism in place

References

National Institute of Standards and Technology. (2023). Artificial Intelligence Risk Management Framework (AI RMF 1.0) (NIST AI 100-1). U.S. Department of Commerce.

National Institute of Standards and Technology. (2020). NIST SP 800-53 Rev. 5 — Security and Privacy Controls for Information Systems and Organizations.

New York City Council. (2021). Local Law 144 — Automated Employment Decision Tools. City of New York.

U.S. Equal Employment Opportunity Commission (EEOC). (2023). Artificial Intelligence and Algorithmic Fairness Initiative.

Colorado General Assembly. (2024). SB 205 — Colorado Artificial Intelligence Act.

Illinois General Assembly. (2019). Artificial Intelligence Video Interview Act (820 ILCS 42).

Executive Office of the President. (2023). Executive Order 14110 — Safe, Secure, and Trustworthy Development and Use of Artificial Intelligence.